The Paradox of Cyber Risk and Patient Safety: A Comprehensive Risk Assessment of IoMT-Enabled Diabetes Therapies

Akiko Takahashi[1,a)] Takao Okubo[1]

Abstract: Type 1 Diabetes (T1D) is a life-threatening autoimmune condition that requires lifelong insulin administration. Internet of Medical Things (IoMT) devices—such as Continuous Glucose Monitors (CGMs) and insulin pumps—can substantially improve clinical outcomes, but their digital connectivity introduces cybersecurity vulnerabilities. Traditional security frameworks often treat connectivity as a pure hazard and do not account for the physical and physiological fail-safes embedded in therapy devices. We investigate the "Cybersecurity–Safety Paradox": connectivity expands the technical attack surface, yet hardware fail-safes (e.g., Max Bolus/Basal limits) bound worst-case physiological harm, whereas manual therapy provides no device-enforced guardrails.
We propose a three-step evaluation framework: (1) systematic threat enumeration using STRIDE and Attack-Defense Trees (ADTrees) under Kordy et al.'s formal semantics, (2) quantitative security risk assessment using the MITRE MD-CVSS rubric, and (3) physiological risk simulation based on clinical personas. Although connectivity increases STRIDE threat counts, attack preconditions and technical guardrails constrain real-world exploitability; hardcoded Max Bolus boundaries reduce the mitigated MD-CVSS Environmental Score to 5.4. For high-risk patients, accepting this highly mitigated, moderate cybersecurity risk can be clinically and ethically necessary to prevent severe, irreversible organ damage.

Keywords: IoMT, Medical Device Security, Threat Modeling, MD-CVSS, Patient Safety

1. Introduction

Type 1 Diabetes (T1D) is a chronic, life-threatening autoimmune condition characterized by the body's inability to produce insulin. Patients must manage blood glucose within a narrow therapeutic window: sustained hyperglycemia leads over years to irreversible microvascular organ damage, including blindness (retinopathy), amputation (neuropathy), and renal failure (nephropathy). Conversely, excessive insulin can trigger acute hypoglycemia, causing seizures, coma, or sudden death within minutes.

To manage this biological tightrope, T1D care is undergoing a major digital transformation driven by the Internet of Medical Things (IoMT). Continuous Glucose Monitors (CGMs) and Sensor-Augmented Pump (SAP) systems automate key aspects of insulin therapy and help patients remain within their target range. However, as devices transition from standalone hardware to connected, cloud-integrated ecosystems, they are exposed to new cybersecurity risks.

Exaggerated public narratives around medical device hacking have created a "Clinical Catch-22": fear of hypothetical cyberattacks can push patients and clinicians back toward unconnected manual therapies, paradoxically increasing exposure to statistically certain harm from severe complications and human dosing errors.

To bridge this gap and provide clinicians with a scientifically grounded decision model, this study formulates and answers three Research Questions:

- **RQ1 (Threat Evolution):** What cybersecurity threats and attack surfaces are introduced across the evolutionary stages of T1D configurations?
- **RQ2 (Quantitative Comparison):** How can we quantitatively score and compare cybersecurity exploitability against clinical safety benefits?
- **RQ3 (Cyber–Safety Balance):** Under what clinical and cognitive conditions does the medical benefit of adopting IoMT devices outweigh the residual cybersecurity risks?

This paper is structured to evaluate the *Cybersecurity-Safety Paradox*: while connected IoMT systems increase the digital attack surface, hardcoded physical and physiological boundaries can constrain worst-case clinical harm, yielding lower overall patient risk than manual therapy.

[1] Institute of Information Security, Yokohama, Japan
[a)] mgs237502@iisec.ac.jp

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

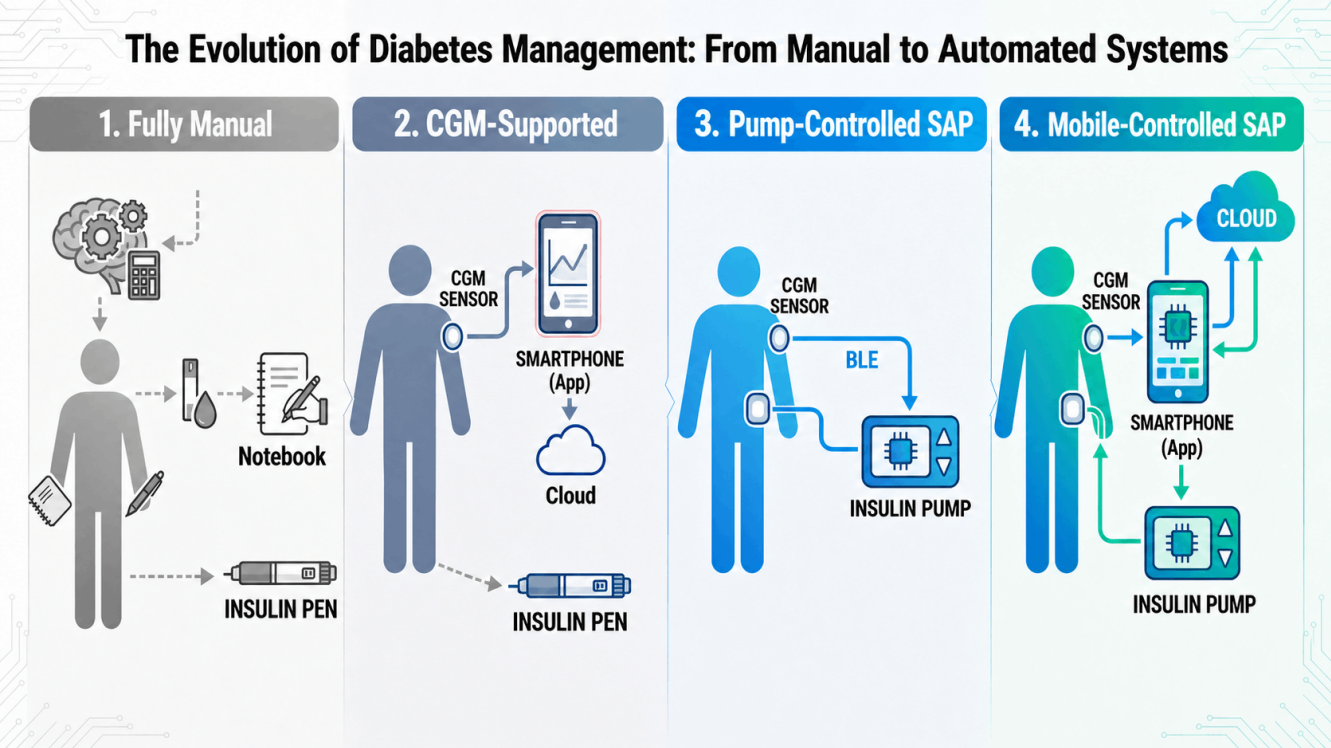


Figure 1: The evolutionary stages of diabetes management technology across the four operational configurations (Modes 1 to 4).

2. Related Work

Medical device security has shifted from standalone evaluations toward structured lifecycle standards. Premarket frameworks such as the FDA's Secure Product Development Framework (SPDF) and Japan's JIS T 81001-5-1 mandate threat modeling during system design. MITRE's *Playbook for Threat Modeling Medical Devices* [1] operationalizes these mandates using Data Flow Diagrams (DFDs) and the STRIDE taxonomy.

In legacy academic security research, Radcliffe's landmark 2011 analysis exposed unencrypted RF transmissions in insulin pumps, while Li et al. reverse-engineered proprietary communication protocols. More recently, Wu et al. (2024) provided a systematic SoK on Bluetooth Low Energy (BLE) protocol-stack exploits. [15]

However, empirical investigations by Thompson et al. (2024) [13] show that security experts struggle to integrate clinical safety mechanisms into traditional IT threat modeling. Furthermore, Kustosch (2025) reports stakeholder experiences and practical barriers to deploying security updates for connected medical devices. [8]

As shown in Table 1, this paper addresses a key gap: there is no unified quantitative framework that evaluates cybersecurity vulnerabilities alongside the baseline clinical risks the devices are designed to mitigate. Standard IT metrics such as CVSS Base Scores often treat connectivity primarily as added exposure, without accounting for clinical and physical constraints that limit real-world harm.

3. Architectural Analysis and Threat Modeling

To systematically map the digital and physical trust boundaries, we model the four dominant operational configurations of diabetes care.

3.1 4 Operational Modes of Diabetes Care

Figure 1 summarizes the four operational configurations and their evolutionary progression (Modes 1 to 4).

- **Mode 1: Fully Manual Therapy.** This operational mode serves as our analog baseline. The core components are the Self-Monitoring of Blood Glucose (SMBG) device, an analog insulin pen, and a physical paper notebook. Patients must measure their blood glucose by repeatedly pricking their fingers for chemical test strips 4 to 10 times a day, perform manual dosing calculations, and inject insulin using mechanical pens. While this configuration carries zero cybersecurity threat, patients are subject to both intentional and unintentional dosing errors without any physical, device-enforced guardrails.
- **Mode 2: CGM-Supported Pen Therapy.** This operational mode enables continuous glucose moni-

© 2026 Information Processing Society of Japan

Table 1: Comprehensive Literature Taxonomy and Cross-Domain Gap Analysis of Related Works.

Author(s) / Org.	Title	Journal / Conference	Vol. / No. / Pages	Publisher	Year	Cyber	Clin.	Cy. ↔ Cl.
Chase et al.	Rubric for Applying CVSS to Medical Devices [1]	—	—	MITRE	2020	✓	△	—
Fan et al.	A Risk Comparison Framework for Autonomous Ships Navigation [3]	Reliability Engineering & System Safety	Vol. 226	—	2022	△	—	—
ISO	ISO 14971:2019 [4]	International Standard	—	ISO	2019	△	✓	—
Kim et al.	APSec1.0: Innovative Security Protocol Design with Formal Security Analysis for the Artificial Pancreas System [5]	Sensors	Vol. 23 · No. 12: 5501	—	2023	✓	△	—
Kordy et al.	Attack-defense Trees [6]	Journal of Logic and Computation	Vol. 24 · No. 1 · pp. 55–87	—	2014	✓	—	—
Ksibi et al.	IoMT Security Model based on Machine Learning and Risk Assessment Techniques [7]	2023 International Wireless Communications and Mobile Computing (IWCMC)	pp. 614–619	IEEE	2023	✓	—	—
Kustosch	Patching Up: Stakeholder Experiences of Security Updates for Connected Medical Devices [8]	34th USENIX Security Symposium	—	USENIX Association	2025	✓	△	—
Li et al.	Hijacking an Insulin Pump: Security Attacks and Defenses for a Diabetes Therapy System [2]	2011 IEEE 13th International Conference on e-Health Networking, Applications and Services	pp. 150–156	IEEE	2011	✓	△	—
MITRE / FDA	Playbook for Threat Modeling Medical Devices [1]	—	—	MITRE	2021	✓	△	—
Thompson et al.	"There are rabbit holes I want to go down that I'm not allowed to go down": An Investigation of Security Expert Threat Modeling Practices for Medical Devices [13]	33rd USENIX Security Symposium	—	USENIX Association	2024	✓	△	—
Tran et al.	T1DMicro: A Clinical Risk Calculator for Type 1 Diabetes Related Microvascular Complications [14]	International Journal of Environmental Research and Public Health	Vol. 18 · No. 21: 11094	—	2021	—	✓	—
Wu et al.	SoK: The Long Journey of Exploiting and Defending the Legacy of King Harald Bluetooth [15]	2024 IEEE Symposium on Security and Privacy (SP)	pp. 2847–228066	IEEE	2024	✓	—	—
Takahashi et al. (This Work)	The Paradox of Cyber Risk and Patient Safety: A Comprehensive Risk Assessment of IoMT-Enabled Diabetes Therapies	Computer Security Symposium 2026	—	CSS	2026	✓	✓	✓

toring through the implementation of a Continuous Glucose Monitor (CGM). The core components are the CGM, a smartphone app, and an analog insulin pen. Glucose telemetry data is streamed automatically from the CGM sensor to the smartphone app over Bluetooth Low Energy (BLE). Insulin dosing calculations and delivery remain entirely manual. This mode introduces a digital attack surface and cybersecurity threats across the CGM, the smartphone app, and the unidirectional wireless telemetry link.

- **Mode 3: Pump-Controlled SAP.** This configuration integrates the CGM sensor with a dedicated insulin pump device acting as the physical actuator. The core components are the CGM sensor, the insulin pump hardware, and (optionally) a companion smartphone app/cloud service used for monitoring, logging, and configuration. The critical property is that the hybrid closed-loop control algorithm and final actuation authority remain on the pump's isolated processor, which calculates and delivers basal insulin based on glucose readings (and patient-entered carbohydrates) even if the app or network is unavailable.
- **Mode 4: Mobile-App-Controlled SAP.** This operational mode also integrates the CGM sensor with the insulin pump actuator. The core components are

© 2026 Information Processing Society of Japan

Table 2: Detailed Threat and Score Breakdown by Attack Surface for Operational Mode 2 (CGM-Supported Insulin Pen).

Attack Surface	Count	Base	Env.
BLE: CGM → MDM App	10	5.2	4.5
Clinician → MDM Cloud	2	5.9	5.7
Inter-process comm in CGM	3	5.2	6.2
Inter-process comm in MDM app	18	5.4	4.9
MDM App → MDM Cloud	13	6.6	6.4
MDM Cloud → Caretaker	2	5.9	5.7
MDM Cloud → Clinician	2	5.9	5.7
Grand Total / Overall Avg.	**50**	**5.7**	**5.4**

Table 3: Detailed Threat and Score Breakdown by Attack Surface for Operational Mode 3 (Pump-Controlled SAP).

Attack Surface	Count	Base	Env.
App → MDM Cloud	10	6.4	6.1
BLE: App → Pump	7	5.2	5.4
BLE: CGM → App	10	5.2	4.2
BLE: Pump → App	17	5.2	4.6
BLE: Pump → CGM	8	5.2	4.6
Clinician → MDM Cloud	4	5.6	5.3
Inter-process comm in MDM app	4	6.6	5.9
Inter-process comm in Pump	9	5.6	6.6
Inter-process comm within CGM	3	6.1	6.6
MDM Cloud → App	28	6.8	6.4
MDM Cloud → Caretaker	4	5.9	5.7
MDM Cloud → Clinician	4	6.7	6.6
Grand Total / Overall Avg.	**108**	**6.0**	**5.6**

the CGM, the insulin pump, and a smartphone application. The defining architectural difference from Mode 3 is the use of the smartphone application as the active loop controller for the insulin pump, running the hybrid closed-loop algorithm and commanding the pump over BLE. This mode splits the trust boundary into four distinct layers: BLE, Mobile OS, Sandbox, and Cloud.

3.2 Data Flow Diagram Preparation (Step 1a)

Based on the 4 operational modes listed in Subsection 3.1, we have prepared hypothetical data flow diagrams (DFD) for the four modes. Figure A·2 (Appendix A.1) illustrates the representative DFD and trust boundary for Mode 2, while Figures 2–5 summarize the overdose-hazard Attack-Defense Tree and controller-architecture views used in our subsequent analysis.

3.3 STRIDE Threat Enumeration (Step 1b)

Applying the STRIDE [12] framework across the communication trust boundaries in our compiled DFDs generated an exhaustive catalog of **272 distinct architectural threats**: 0 in Mode 1, 50 in Mode 2, 108 in Mode 3, and 114 in Mode 4.

Table 4: Detailed Threat and Score Breakdown by Attack Surface for Operational Mode 4 (Mobile-Controlled SAP).

Attack Surface	Count of Threats	Base	Env.
BLE: App → Pump	7	6.4	6.2
BLE: CGM → Pump	9	5.2	4.8
BLE: Pump → MDM App	7	5.6	5.6
Clinician → MDM Cloud	2	8.0	5.7
Inter-process comm in MDM app	61	5.6	5.1
Inter-process within CGM	3	5.2	5.7
MDM App → MDM Cloud	7	6.2	5.6
MDM Cloud → Caretaker	2	8.0	5.7
MDM Cloud → Clinician	2	8.0	5.7
MDM Cloud → MDM App	14	7.9	6.7
Grand Total / Overall Average	**114**	**6.1**	**5.4**

3.4 Attack-Defense Tree (ADTree) Modeling (Step 1c)

To map how these IT exploits interact with clinical safety controls, we construct Attack-Defense Trees (ADTrees) under Kordy et al.'s formal semantics. Technical exploits (STRIDE threats) are mapped as Attack nodes (red), while hardcoded fail-safes are mapped as Defense nodes (green).[6]

3.5 Quantitative Cybersecurity Assessment (Step 2)

Standard CVSS Base Scores overrate medical device risk because they score software bugs in a vacuum. To resolve this, we applied the FDA-recognized **MITRE MD-CVSS Rubric**[1] to programmatically calculate mitigated Environmental Scores for all 272 threats.

The results (Table 5) reveal that while standard Base Scores rose with connectivity (from 5.7 in Mode 2 to a critical 6.1 in Mode 4), the Environmental Scores plummeted to **5.4** in Mode 4, perfectly matching the risk profile of Mode 2. This mathematically proves that built-in fail-safes successfully bound and neutralize the residual cybersecurity risk, downgrading it to a moderate, managed level.

Critical Finding: Under manual Modes 1 and 2, there is no system-level defense node to prevent the delivery of a fatal insulin dose. In contrast, under automated Modes 3 and 4, there is a hardcoded, un-bypassable defense node at the very top of our tree: the **Max Bolus and Basal Limit** on the physical pump's isolated processor. Even if an attacker completely compromises the smartphone app or intercepts the BLE link, the pump's isolated hardware physically refuses any command exceeding these safety boundaries, neutralizing a lethal overdose.

3.6 Fatal Cyberattack Pre-Conditions

Our modeling defines strict physical and mathematical

© 2026 Information Processing Society of Japan

Table 5: Quantitative Vulnerability Scoring Comparison Across IoMT Evolutionary Modes.

Metric / Parameter	Mode 1: Fully Manual	Mode 2: CGM + Pen	Mode 3: Pump SAP	Mode 4: Mobile SAP
Digital Trust Boundaries	0	1 (BLE)	2 (BLE, Hardware)	4 (BLE, OS, App, Cloud)
Identified Cyber Threats (STRIDE)	0	50	108	114
Average CVSS Base Score	N/A	5.7 (Medium)	6.0 (Medium)	6.1 (Medium)
Average MD-CVSS Env. Score	N/A	**5.4** (Medium)	**5.6** (Medium)	**5.4** (Medium)
Ultimate Clinical Safety Level	Lowest (No Defense)	Moderate	Highest (Automated limits)	High (Automated limits)

preconditions required for an adversary to execute a successful attack in a clinical setting:

(1) **Proximity Range Bounds:** Local wireless attacks require close physical proximity. Manufacturer guides in our literature restrict active BLE communications to within **1.5 meters** for Terumo and Tandem Mobi devices.

(2) **Out-of-Band Pairing Constraints:** Active pairing requires manually reading and entering a physical PIN printed on the pump chassis, blocking silent, drive-by Bluetooth pairing.

(3) **Extreme Target Sparsity:** According to the IDF Diabetes Atlas (2025), T1D patients comprise 0.11% of the global population, and only **0.04% to 0.05%** of the population utilizes an active pump. The probability of an attacker randomly crossing paths with an active pump in public is nearly zero.

4. Clinical Trade-off Evaluation (Step 3)

To resolve the IT-clinical gap, we integrate our miti-

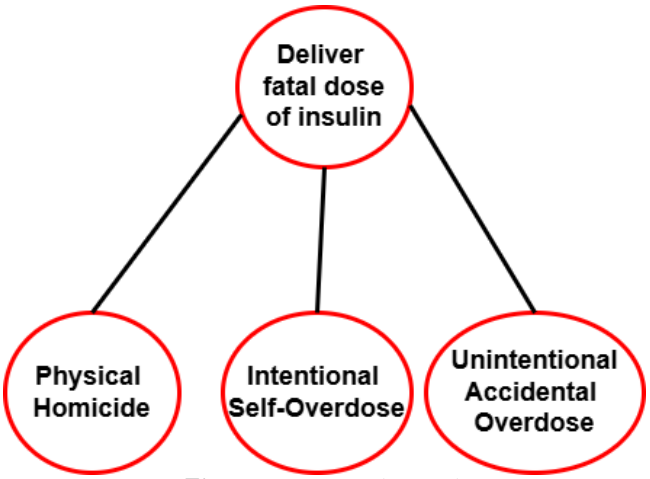


Figure 2: ADTree (Mode 1)

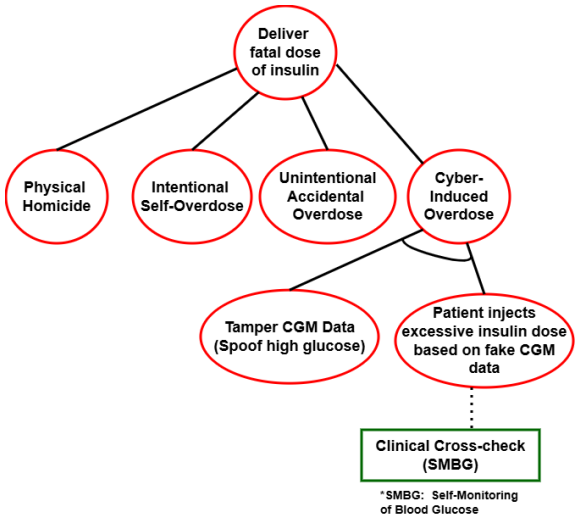


Figure 3: ADTree (Mode 2)

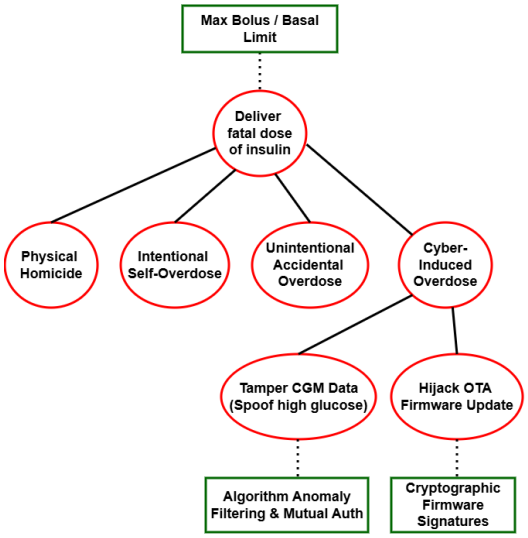


Figure 4: ADTree (Mode 3)

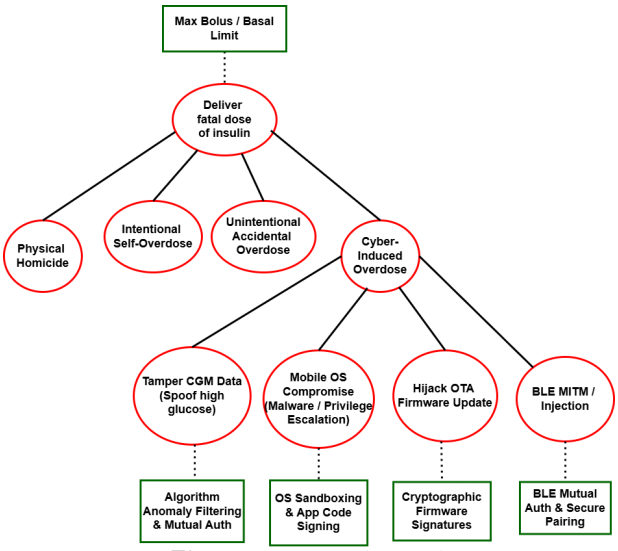


Figure 5: Schema (Mode 4)

© 2026 Information Processing Society of Japan

gated security scores with 10-year microvascular complication probabilities calculated via the validated **T1DMicro calculator** (Tran et al., 2021).[14]

4.1 The "Zero-Threat" Illusion of Manual Pens

Under standard STRIDE, manual therapy has zero cyber threats and a CVSS of 0.0, suggesting it is the safest option. But our clinical simulations prove that manual therapy is physiologically lethal.

- **Case 1: The High-Risk Patient (HbA1c 9.5%, 20-yr T1D duration).** Remaining on manual therapy carries a catastrophic **28.9% probability of blindness** (retinopathy) and a **12.3% probability of kidney failure** (nephropathy) over 10 years. Transitioning them to automated Mode 4 reduces HbA1c to 7.5%, slashing retinopathy risk to 23.4% and nephropathy to 8.0%. Accepting a highly mitigated, moderate cybersecurity risk of 5.4 is clinically and ethically mandatory to prevent severe, irreversible organ damage.
- **Case 2: The Cognitive/Pediatric Vulnerability (Dementia or Children).** A 5-year-old child or elderly patient with dementia lacking self-management capacity. Under Mode 1 manual therapy, they are completely dependent on caregivers, presenting high safety risks from caregiver double-dosing errors or uncommunicated hypoglycemia. Transitioning to Mode 4 Mobile SAP introduces external cloud cyber threats, but provides a crucial automated safety net via Predictive Low Glucose Suspend (PLGS) to autonomously stop insulin during nocturnal hypoglycemia, completely justifying the cyber-physical risk.
- **Case 3: The Intentional Harm Risk (Psychiatric / Suicidal Ideation).** A patient with severe depression or active suicidal ideation. Under Mode 1 manual therapy, an analog insulin pen lacks access controls and is a highly lethal, untraceable weapon for intentional overdose, allowing up to 300 units to be delivered in a single mechanical action. Literature indicates that diabetes-related chronic distress increases suicide and homicide risks via insulin self-poisoning [9–11]. In contrast, automated Mode 3 or 4 pumps enforce hardcoded, firmware-level Max Bolus and Basal limits that physically refuse lethal overdosing commands even if a patient or external attacker attempts to abuse the interface, acting as a crucial physical defense barrier.
- **Case 4: The Low-Risk Patient (HbA1c 6.0%, 5-yr T1D duration).** Highly disciplined. Baseline retinopathy risk is only 0.3%. Adopting Mode 4 introduces residual cybersecurity risk for negligible clinical gain, meaning the transition is not medically justified.
- **Case 5: The Hypertensive Patient (HbA1c 6.5%, SBP 150 mmHg).** Adopting Mode 4 offloads cognitive burden, reducing stress and SBP by 20 mmHg, cutting retinopathy risk from 19.1% to 10.9%, demonstrating that cybersecurity risk can be accepted to address secondary physiological stressors.

4.2 Shared Decision-Making (SDM) Tool Design

To translate this framework into clinical practice, we proposed the architectural design for a Clinical Shared Decision-Making software tool. Driven by parallel clinical (T1DMicro) and cybersecurity (MD-CVSS) engines, the tool plots patients onto a dual-axis visual dashboard (X-axis: medical risk reduction, Y-axis: residual cybersecurity risk) to output an objective Net Patient Benefit recommendation.

5. Discussion & Systemic Implications

5.1 The Duality of MD-CVSS

An insightful "duality" within the MD-CVSS framework was observed. Internal threats (e.g., inter-process communication within pump firmware) typically yield low CVSS Base Scores because they require local access. However, since they represent safety-critical core functions, high Integrity and Availability Requirements (IR:H, AR:H) are applied under the MD-CVSS rubric, resulting in an upward adjustment of the Environmental Score.

Conversely, external network threats (e.g., cloud-to-app communications) exhibit high Base Scores (≥ 8.0) due to remote exploitability, but because physical and algorithmic limits act as robust mitigations, their Environmental Scores are significantly downgraded. This proves that MD-CVSS accurately reflects the severity of ultimate clinical harm rather than merely the ease of IT exploitation.

5.2 Limitations

Our evaluation is theoretically scoped based on architectural specifications rather than empirical penetration testing of proprietary firmware. Additionally, MD-CVSS scoring relies on qualitative, expert-elicited judgments regarding mitigation effectiveness, which can introduce assessor bias.

© 2026 Information Processing Society of Japan

Table 6: Unified Cross-Domain Risk–Benefit Matrix (Combined Risk Analysis based on Conclusion.csv).

Type of Risk	Method / Persona	Mode 1 Manual	Mode 2 CGM+Pen	Mode 3 Pump SAP	Mode 4 Mobile SAP
Cyber risk	STRIDE + MD-CVSS (Env.)	None	Med. (Env. 5.4)	Med. (Env. 5.6)	Med. (Env. 5.4)
Fatal overdose risk	Attack–Defense Trees	Crit. (no defense)	High (alerts)	Low (max dose)	Low (max dose)
Persona-based medical risk	Case 1: High-risk (poor control)	High comp. risk	Comp. risk reduced (alerts)	Comp. risk reduced (alerts+auto)	Comp. risk reduced (alerts+auto)
	Case 2: Cognitive / pediatric	Crit. caregiver harm risk	Fatal risk reduced (monitor+alerts)	Low fatal risk (auto limits)	Low fatal risk (auto limits)
	Case 3: Intentional harm	Crit. self-overdose risk	Crit. self-overdose risk	Low fatal risk (max dose)	Low fatal risk (max dose)
	Case 4: Low-risk, strict control	Low	Low	Low	Low
	Case 5: Hypertensive (controlled)	High	High	High to Low	High to Low
Overall safety	**Overall conclusion**	Lowest (no limits)	Moderate (alerts)	High (hard limits)	High (hard limits)

6. Conclusion

Figure 6 summarizes the integrated clinical–cyber risk trade-off presented in this study.

This study investigated the "Cyber–Safety Paradox": although connected medical architectures increase the number of theoretical cyber threats, automated clinical fail-safes can neutralize their worst-case physiological impact. Using STRIDE threat modeling, Attack-Defense Trees, and the MITRE MD-CVSS rubric across four evolutionary operational modes, we provide a quantitative demonstration of this effect.

Our results show that the most advanced Mobile-Controlled SAP architecture (Mode 4) yields 114 distinct threats with an average CVSS Base Score of 6.1. However, due to system-bounded delivery limits and autonomous fail-safes, the average MD-CVSS Environmental Score drops to 5.4. Notably, this residual risk level matches the risk profile of a CGM-Supported Insulin Pen (Mode 2), which lacks digital attack surfaces for remote insulin delivery but provides no automated defense against human dosing error. Overall, these findings suggest that evaluating medical device security solely through IT vulnerability metrics can misrepresent patient risk; safety-relevant physical mitigations must be considered alongside cybersecurity controls.

7. Future Work

Building upon the framework established in this study, future work will focus on two directions.

First, we will develop a dynamic, software-based risk comparison tool for clinical settings. By integrating medical risk and cybersecurity risk, the tool will support Healthcare Delivery Organizations (HDOs), clinicians, and patients in Shared Decision Making (SDM) and enable stakeholders to quantitatively weigh trade-offs between cybersecurity vulnerabilities and clinical benefit when adopting new IoMT technologies.

Second, we will extend this comparative risk assessment methodology to other classes of medical devices. In particular, we will evaluate in-hospital IoMT equipment—such as patient monitors, infusion pumps, and robotic surgical systems—that operate in different deployment environments. Unlike consumer-facing diabetes devices, in-hospital IoMT systems often have longer lifespans, run legacy software, and face severe logistical barriers to security patching and firmware updates. Applying our framework to these settings will help determine whether the Cyber–Safety Paradox holds when devices are more exposed to network-based attacks but lack rapid update and oversight mechanisms.

References

[1] Elaine Bochniewicz. Playbook for Threat Modeling Medical Devices. November 2021.

[2] Chunxiao Li, Anand Raghunathan, and Niraj K. Jha. Hijacking an insulin pump: Security attacks and defenses for a diabetes therapy system. *2011 IEEE 13th International Conference on e-Health Networking, Applications and Services*, pages 150–156, June 2011. DOI: 10.1109/HEALTH.2011.6026732. URL . Conference Name: 2011 IEEE 13th International Conference on e-Health Networking, Applications and Services (Healthcom 2011) ISBN: 9781612846958.

[3] Cunlong Fan, Jakub Montewka, and Di Zhang. A risk comparison framework for autonomous ships navigation. *Reliability Engineering & System Safety*, 226:108709, October 2022. ISSN 0951-8320. DOI: 10.1016/j.ress.2022.108709. URL .

[4] ISO. ISO 14971:2019, December 2019. URL .

© 2026 Information Processing Society of Japan

[5] Jiyoon Kim, Jongmin Oh, Daehyeon Son, Hoseok Kwon, Philip Virgil Astillo, and Ilsun You. APSec1.0: Innovative Security Protocol Design with Formal Security Analysis for the Artificial Pancreas System. *Sensors*, 23(12):5501, June 2023. ISSN 1424-8220. DOI: 10.3390/s23125501. URL .

[6] B. Kordy, S. Mauw, S. Radomirovic, and P. Schweitzer. Attack-defense trees. *Journal of Logic and Computation*, 24(1):55–87, February 2014. ISSN 0955-792X, 1465-363X. DOI: 10.1093/logcom/exs029. URL .

[7] Sondes Ksibi, Faouzi Jaidi, and Adel Bouhoula. IoMT Security Model based on Machine Learning and Risk Assessment Techniques. In *2023 International Wireless Communications and Mobile Computing (IWCMC)*, pages 614–619, Marrakesh, Morocco, June 2023. IEEE. ISBN 979-8-3503-3339-8. DOI: 10.1109/IWCMC58020.2023.10182654. URL .

[8] Lorenz Kustosch. Patching Up: Stakeholder Experiences of Security Updates for Connected Medical Devices. In *Patching Up: Stakeholder Experiences of Security Updates for Connected Medical Devices*. USENIX Association, August 2025. ISBN 978-1-939133-52-6. URL .

[9] Vincent Marks. Murder by insulin: suspected, purported and proven—a review. *Drug Testing and Analysis*, 1(4):162–176, April 2009. ISSN 1942-7603, 1942-7611. DOI: 10.1002/dta.38. URL .

[10] Kristin S. Russell, Jonathan R. Stevens, and Theodore A. Stern. Insulin Overdose Among Patients With Diabetes: A Readily Available Means of Suicide: (Rounds in the General Hospital). *The Primary Care Companion to The Journal of Clinical Psychiatry*, 11(5):258–262, October 2009. ISSN 1555-211X. DOI: 10.4088/PCC.09r00802. URL .

[11] Szymon Rzepczyk, Klaudia Dolińska-Kaczmarek, Aleksandra Uruska, and Czesław Żaba. The Other Face of Insulin—Overdose and Its Effects. *Toxics*, 10(3):123, March 2022. ISSN 2305-6304. DOI: 10.3390/toxics10030123. URL .

[12] Adam Shostack. *Threat modeling: designing for security*. Wiley, Indianapolis, IN, 2014. ISBN 978-1-118-80999-0.

[13] Ronald Thompson, Madeline McLaughlin, Carson Powers, and Daniel Votipka. "There are rabbit holes I want to go down that I'm not allowed to go down": An Investigation of Security Expert Threat Modeling Practices for Medical Devices.

[14] Paul Minh Huy Tran, Eileen Kim, Lynn Kim Hoang Tran, Bin Satter Khaled, Diane Hopkins, Melissa Gardiner, Jennifer Bryant, Risa Bernard, John Morgan, Bruce Bode, John Chip Reed, Jin-Xiong She, and Sharad Purohit. T1DMicro: A Clinical Risk Calculator for Type 1 Diabetes Related Microvascular Complications. *International Journal of Environmental Research and Public Health*, 18(21):11094, October 2021. ISSN 1660-4601. DOI: 10.3390/ijerph182111094. URL .

[15] Jianliang Wu, Ruoyu Wu, Dongyan Xu, Dave Jing Tian, and Antonio Bianchi. SoK: The Long Journey of Exploiting and Defending the Legacy of King Harald Bluetooth. In *2024 IEEE Symposium on Security and Privacy (SP)*, pages 2847–228066, San Francisco, CA, USA, May 2024. IEEE. ISBN 979-8-3503-3130-1. DOI: 10.1109/SP54263.2024.00023. URL .

© 2026 Information Processing Society of Japan

Appendix

A.1 Data Flow Diagrams (DFDs) of Diabetes Care Operational Modes

To illustrate the data flows and trust boundaries mapped during Step 1 of our evaluation, we present the Data Flow Diagrams (DFDs) for each operational configuration.

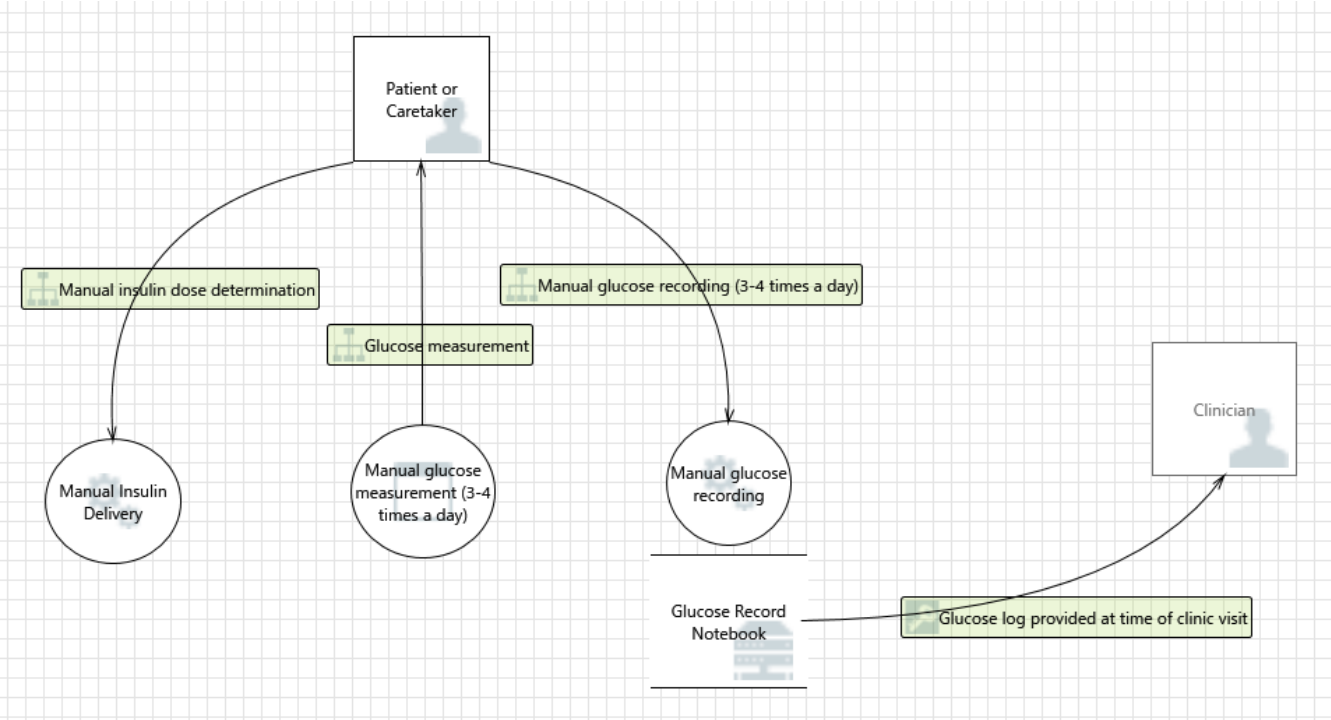


Figure A·1: Data Flow Diagram for Mode 1: Fully Manual Therapy

© 2026 Information Processing Society of Japan

© 2026 Information Processing Society of Japan

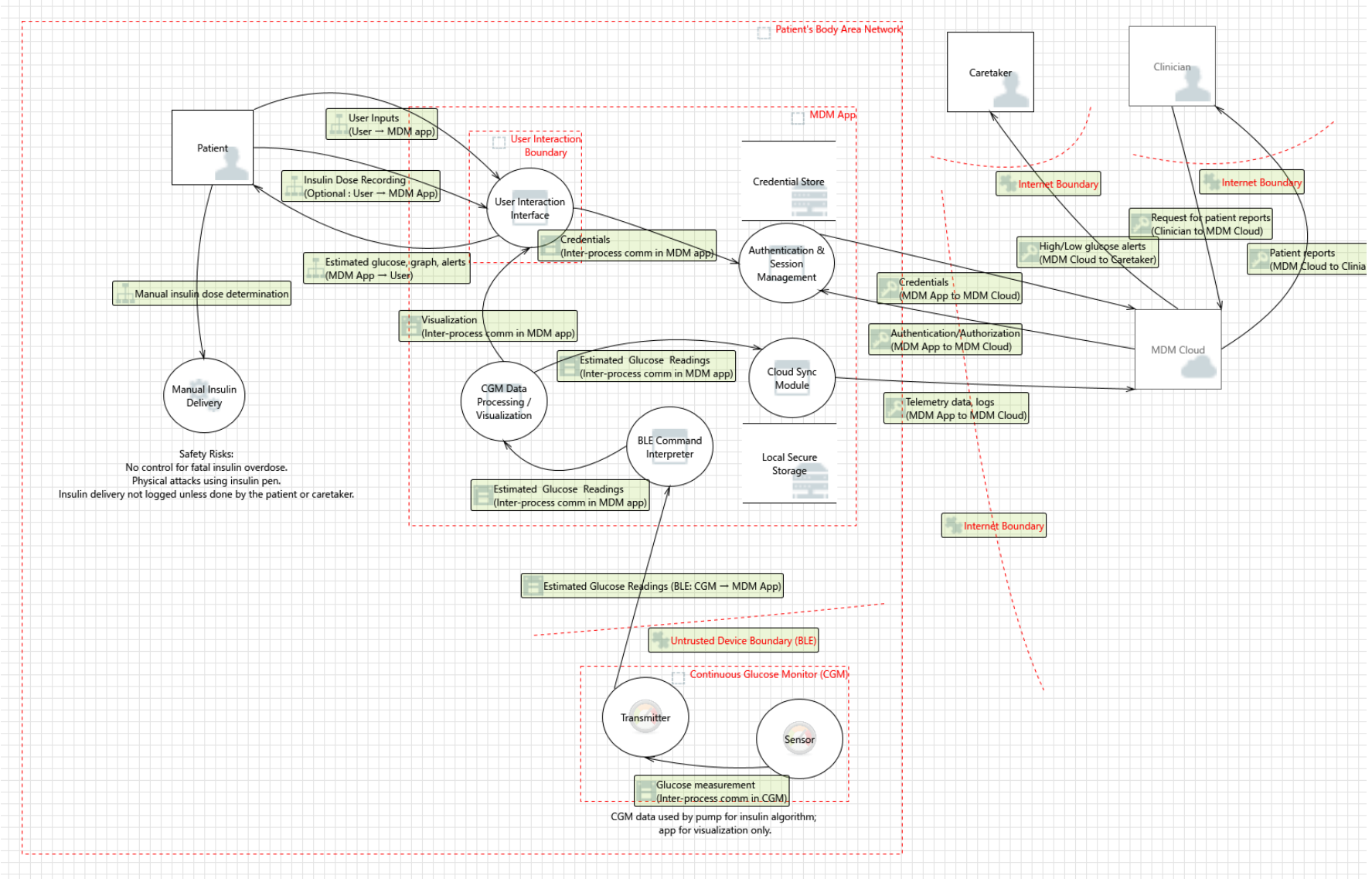


Figure A·2: Data Flow Diagram for Mode 2: CGM-Supported Pen Therapy

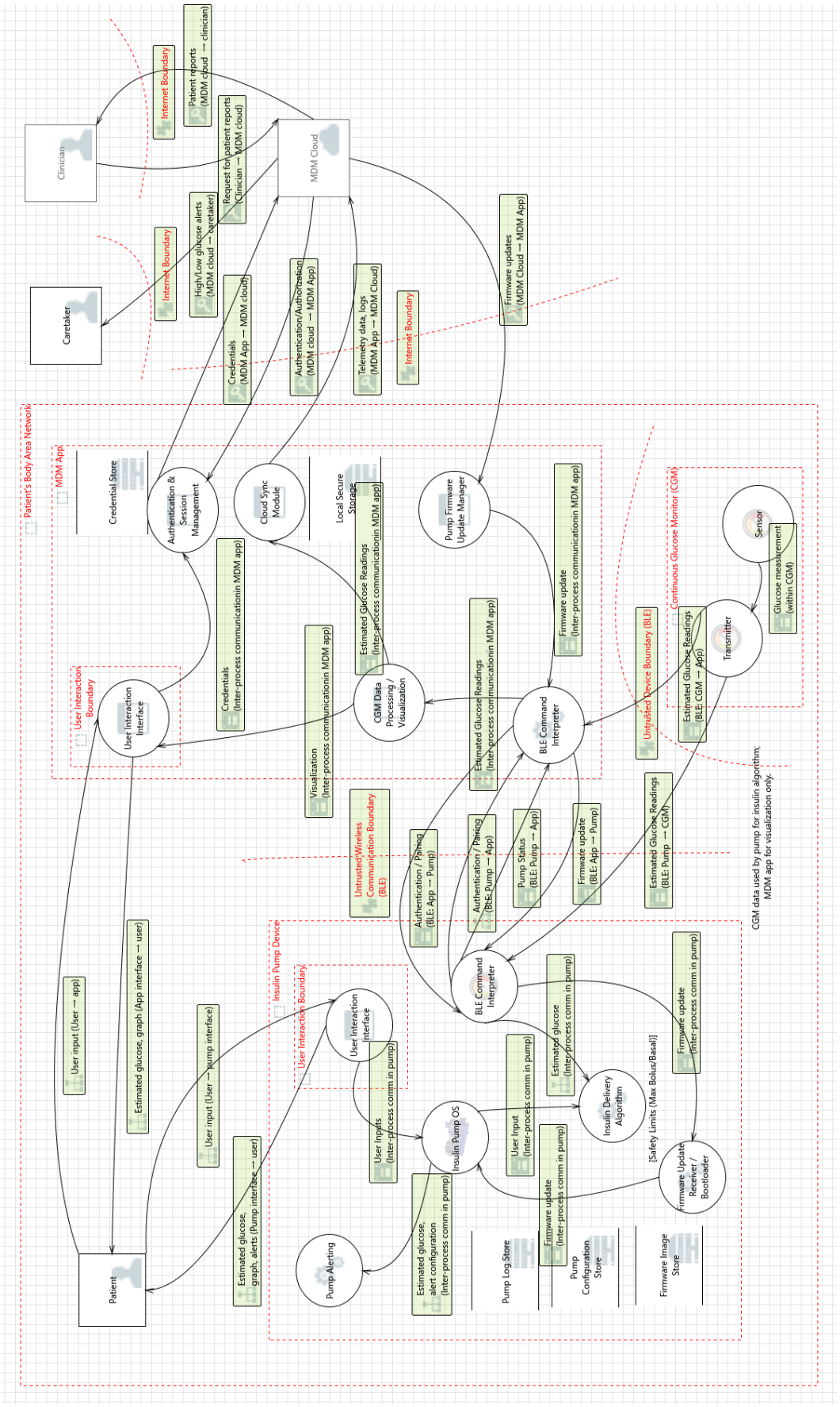


Figure A·3: Data Flow Diagram for Mode 3: Pump-Controlled SAP

© 2026 Information Processing Society of Japan

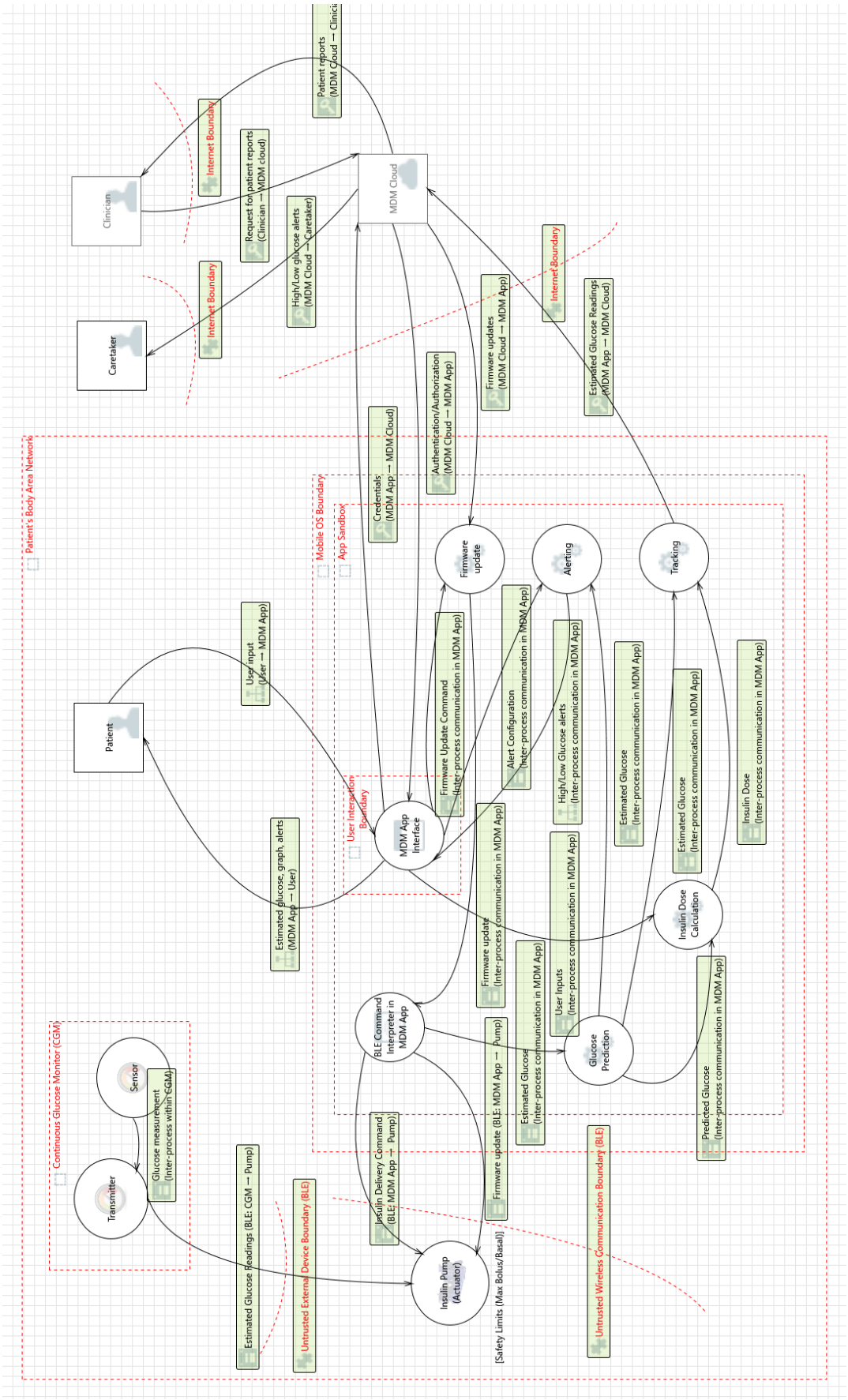


Figure A·4: Data Flow Diagram for Mode 4: Mobile-App-Controlled SAP

© 2026 Information Processing Society of Japan